

VULNHUB: WEB MACHINE: (N7)

Author: mapanit

Date: 10.07.2026

Target IP: 10.0.2.15

Attacker IP: 10.0.2.6

Difficulty: Medium

Executive Summary

Целевое веб-приложение содержало две связанные уязвимости в логике контроля доступа:

1. Форма на странице exploit.html жёстко ссылалась на localhost вместо адреса приложения - после исправления адреса в запросе на клиенте открылась первая часть флага.
2. Механизм аутентификации на странице enter_network был реализован небезопасно: значение из формы отправляется на сервер как MD5-хэш в cookie, без серверной проверки подлинности. Перехват запроса через Burp Suite и подмена значения роли в этой кукле на admin дали доступ к защищённой странице admin.php и вторую часть флага.

Обе уязвимости относятся к классу **Broken Access Control / Insecure Session Management (OWASP A01:2021)** - сервер доверяет данным, поступающим от клиента, без независимой проверки.

Перечисление сетей

Определение цели

ifconfig

nmap 10.0.2.1/24

Целевая машина обнаружена по адресу **10.0.2.15**.

```
(kali@kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.6 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fe80::ed80:fb7:fbca:2e63 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:24:da:43 txqueuelen 1000 (Ethernet)
    RX packets 5206 bytes 335881 (328.0 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 5771 bytes 356336 (347.9 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 958 bytes 42280 (41.2 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 958 bytes 42280 (41.2 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

(kali@kali)-[~]
$ nmap 10.0.2.1/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-20 08:55 -0400
Nmap scan report for 10.0.2.1
Host is up (0.0016s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp   open  msrpc
445/tcp   open  microsoft-ds
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)

Nmap scan report for 10.0.2.2
Host is up (0.00023s latency).
All 1000 scanned ports on 10.0.2.2 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 08:00:27:87:FD:A5 (Oracle VirtualBox virtual NIC)

Nmap scan report for 10.0.2.15
Host is up (0.00067s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
MAC Address: 08:00:27:ED:BD:C7 (Oracle VirtualBox virtual NIC)
```

Сканирование портов и служб

`nmap -A 10.0.2.15`

Результат: открыт порт **80/tcp** - HTTP.

```
└─$ nmap -A 10.0.2.15
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-20 09:02 -0400
Nmap scan report for 10.0.2.15
Host is up (0.00091s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.46 ((Debian))
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.4.46 (Debian)
MAC Address: 08:00:27:ED:BD:C7 (Oracle VirtualBox virtual NIC)
Device type: general purpose/router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop

TRACEROUTE
HOP RTT      ADDRESS
1   0.91 ms  10.0.2.15

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.66 seconds
```

При первом визуальном осмотре сайт выглядел практически пустым - без явного функционала.



WELCOME IN BLOG

this is first blog

Первый проход - dirsearch:

`dirsearch -u http://10.0.2.15/`

Результат минимальный, значимых путей не найдено.

Перечисление каталогов

Перечисление каталогов

`dirsearch -u http://10.0.2.15/`

Результат минимальный, значимых путей не найдено.

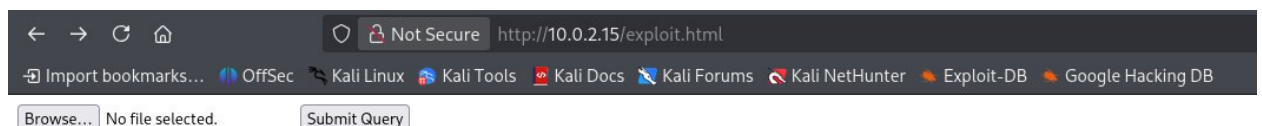
```
└─$ dirsearch -u http://10.0.2.15/
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict
dirsearch v0.4.3
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/kali/reports/http_10.0.2.15/_26-07-20_12-00-16.txt
Target: http://10.0.2.15/
[12:00:16] Starting:
[12:00:19] 403 - 2748 - /.ht_wsr.txt
[12:00:19] 403 - 2748 - /.htaccess.bak1
[12:00:19] 403 - 2748 - /.htaccess.orig
[12:00:19] 403 - 2748 - /.htaccess.save
[12:00:19] 403 - 2748 - /.htaccess_extra
[12:00:19] 403 - 2748 - /.htaccess_orig
[12:00:19] 403 - 2748 - /.htaccessBAK
[12:00:19] 403 - 2748 - /.htaccess_sc
[12:00:19] 403 - 2748 - /.htaccessOLD
[12:00:19] 403 - 2748 - /.htaccessOLD2
[12:00:19] 403 - 2748 - /.htm
[12:00:19] 403 - 2748 - /.html
[12:00:19] 403 - 2748 - /.httpswd_test
[12:00:19] 403 - 2748 - /.httpswds
[12:00:19] 403 - 2748 - /.httr-oauth
[12:00:21] 403 - 2748 - /.php
[12:00:25] 403 - 2748 - /.htaccess.sample
[12:00:53] 301 - 3118 - /javascript → http://10.0.2.15/javascript/
[12:01:06] 200 - 5188 - /profile.php
[12:01:09] 403 - 2748 - /server-status
[12:01:09] 403 - 2748 - /server-status/
```

Дополнительный проход - gobuster:

`gobuster dir -u http://10.0.2.15/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x html,php,txt`

```
└─$ gobuster dir -u http://10.0.2.15/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x html,php,txt
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
[+] Url: http://10.0.2.15/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: html,php,txt
[+] Timeout: 10s
Starting gobuster in directory enumeration mode
index.html (Status: 200) [Size: 1620]
profile.php (Status: 200) [Size: 1473]
javascript (Status: 301) [Size: 311] [→ http://10.0.2.15/javascript/]
exploit.html (Status: 200) [Size: 279]
Progress: 213872 / 882232 (24.24%)
```

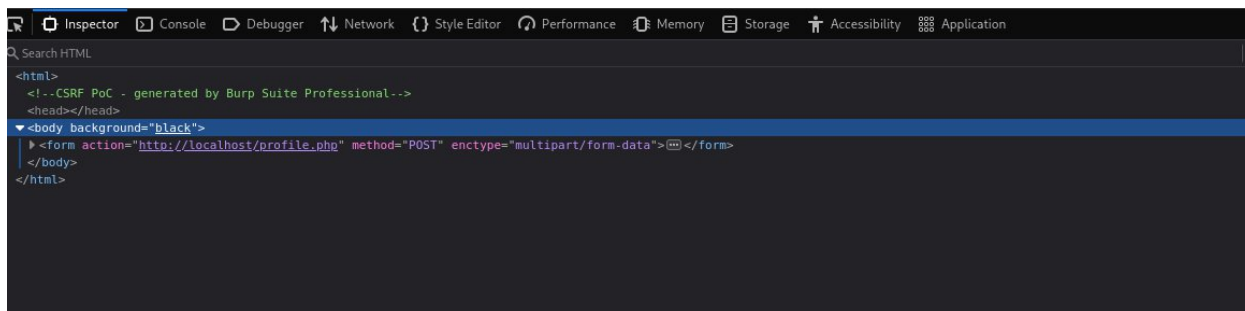
Уже лучше, заходим в exploit.html



Уязвимость №1 - Open Redirect / Broken form target (exploit.html)

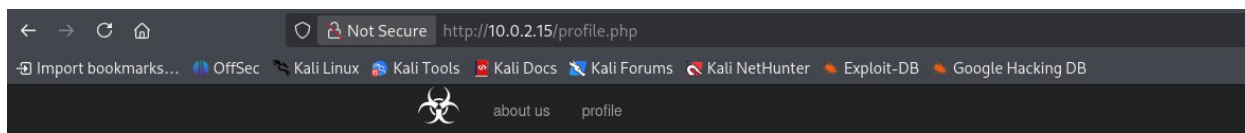
При открытии exploit.html и нажатии **Submit** возникала ошибка соединения.

При анализе исходного кода страницы выяснилось, что форма отправляет запрос на localhost вместо адреса целевой машины.



```
<html>
<!--CSRF PoC - generated by Burp Suite Professional-->
<head></head>
<body background="black">
  <form action="http://localhost/profile.php" method="POST" enctype="multipart/form-data"></form>
</body>
</html>
```

Эксплуатация: запрос вручную перенаправлен на 10.0.2.15, после чего **Submit Query** вернул первую часть флага.



FLAG{N7

Обход тупика в enumeration - доступ к файловой системе через сброс root

На этом этапе я столкнулся с проблемой: не мог дальше продвинуться и начал смотреть различные ресурсы, нашел источник в котором описывается как сбросить пароль в уязвимой машине kali linux в котором базируется сам сайт. Нужно перейти в каталог /var/www/html и там имеется exploit.html и enter_network

[Как сбросить пароль root в Kali Linux](#)

Уязвимость №2 - Insecure cookie-based auth / IDOR (enter_network, admin.php)

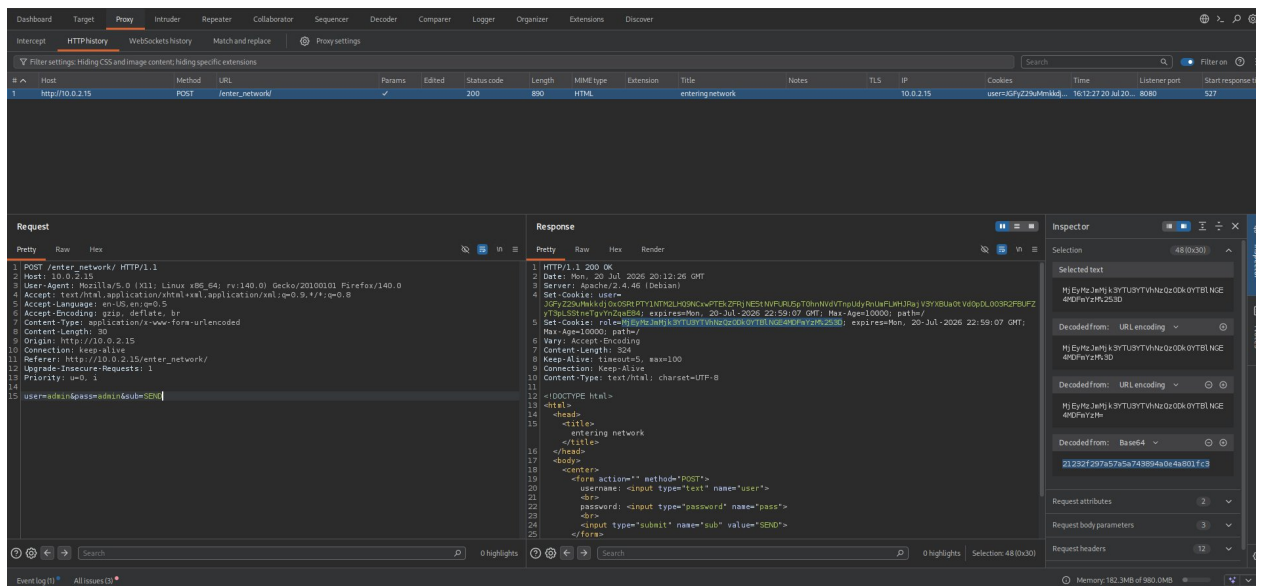
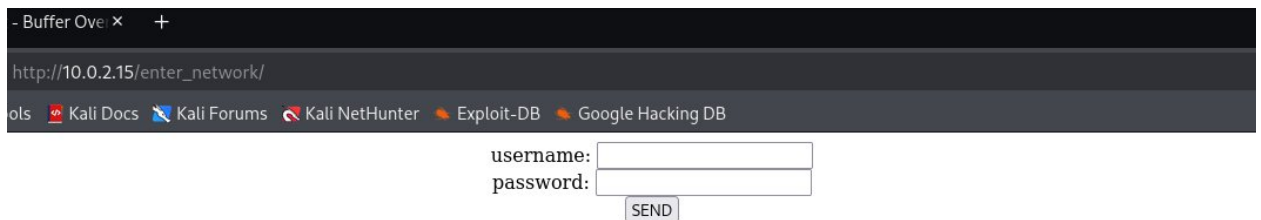
На странице enter_network при вводе значения admin в форму и перехвате запроса через Burp Suite в ответе сервера обнаружен cookie-параметр:

MjEyMzJmMjk3YTU3YTVhNzQzODk0YTBINGE4MDFmYzM

После декодирования Base64:

21232f297a57a5a743894a0e4a801fc3

Это MD5-хэш строки admin (проверено через онлайн-сервис подбора хэшей, gromweb.com).



сервер не хранит и не проверяет сессию самостоятельно - вместо этого он берёт значение поля формы, хэширует его на клиенте/сервере через MD5 и кладёт в cookie как единственный признак подлинности. Это позволяет подделать любое значение, зная, что сервер лишь сравнивает хэши.

Поиск защищённых эндпоинтов

gobuster dir -u http://10.0.2.15/enter_network -w

/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x html,php

Обнаружен admin.php - при прямом обращении возвращал сообщение об отказе в доступе.

```
(kali@kali)-[~]
$ gobuster dir -u http://10.0.2.15/enter_network -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x html,php

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:             http://10.0.2.15/enter_network
[+] Method:          GET
[+] Threads:         10
[+] Wordlist:         /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent:       gobuster/3.8.2
[+] Extensions:      html,php
[+] Timeout:         10s

Starting gobuster in directory enumeration mode

index.php      (Status: 200) [Size: 324]
admin.php      (Status: 200) [Size: 126]
Progress: 7107 / 661677 (1.07%)

admin interface x FoxyProxy Options x +
← → ↻ ⌂ Not Secure http://10.0.2.15/enter_network/admin.php
Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

this interface is admin only
```

Эксплуатация

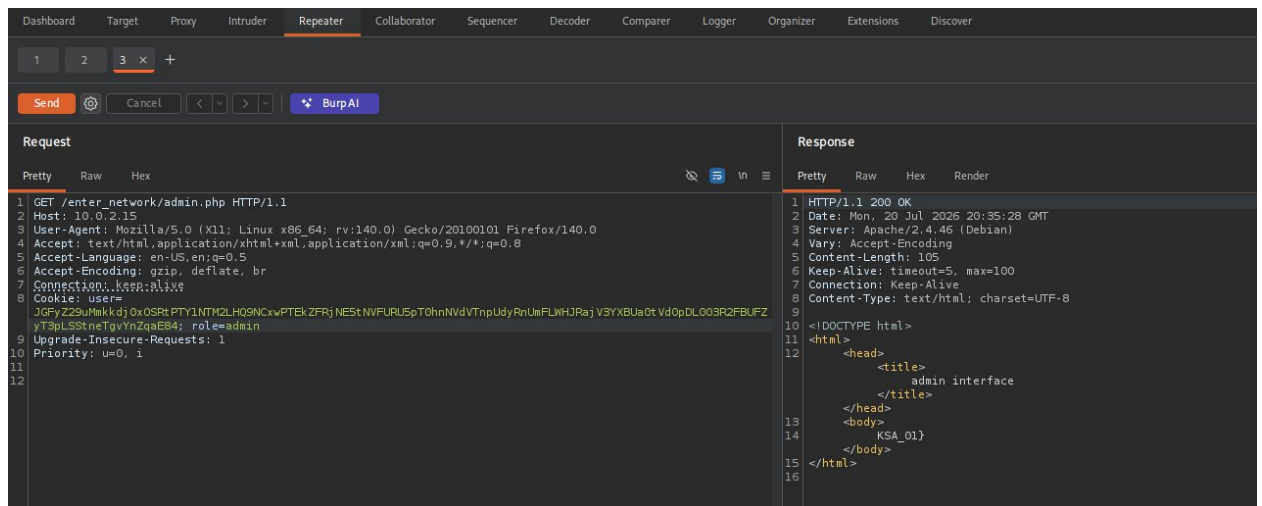
Запрос к admin.php отправлен в **Burp Repeater**. При замене значения cookie/параметра роли на admin доступ был получен, и на странице отобразилась вторая часть флага.

```
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Orga

1 2 3 x +

Send [Settings] Cancel < > Burp AI

Request
Pretty Raw Hex
1 GET /enter_network/admin.php HTTP/1.1
2 Host: 10.0.2.15
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Cookie: user=
JGFyZ29uMmkkdj0xOSRtPTY1NTM2LH09NCxwPTEkZFRjNEStNVFURUSpT0hnNVdVTnpUdyRnUmFLWHJRajV3YXBua0tVd0pDL003R2FBUFZ
yT3pLSStneTgvYnZqaE84; role=MjEyMzJmMjY3YTU3YTZhNzQzODk0YTBlNGE4MDFmYzFm%253D
9 Upgrade-Insecure-Requests: 1
10 Priority: u=0, i
11
12
```



Получаем вторую часть флага

FLAG{N7KSA_01}